

UNIVERSIDAD SAN FRANCISCO XAVIER DE CHUQUISACA
FACULTAD DE TECNOLOGÍA



Auditoria de Sistemas

Estudiantes:

Lopez Chavez Pablo	Ing. Ciencias de la Computación
Lujan Renteria David Fernando	Ing. Sistemas
Gutierrez Coronado Matias Ezequiel	Ing. Sistemas
Rua Echalar Juan Manuel	Ing. Ciencias de la Computación

Fecha: 13/10/2025

Grupo: 2

SIS-316
Sucre - 2025

Análisis de Riesgos en una Auditoría de Sistemas

CASO de Estudio : Auditoría de la Aplicación Web de la Universidad San Francisco Xavier de Chuquisaca (usfx.bo)

Establecimiento del Contexto

El contexto de análisis de los riesgos del caso se centra en la evaluación de la seguridad de la información en una aplicación web pública de una institución educativa boliviana, alineado con los principios de gestión de riesgos establecidos en ISO27005 (que enfatiza la identificación, análisis y tratamiento de riesgos en la seguridad de la información mediante un enfoque sistemático y continuo) e ISO31000 (que proporciona un marco genérico para la gestión de riesgos, promoviendo la integración de riesgos en los procesos organizacionales para mejorar la toma de decisiones y la resiliencia). Este análisis considera amenazas comunes en entornos web educativos, como aquellas derivadas de modelos como OWASP Top 10 y STRIDE, para identificar vulnerabilidades que podrían comprometer la confidencialidad, integridad y disponibilidad de los datos.

¿De qué entidad se trata ? ¿Qué sistema o proceso?

La entidad es la Universidad Mayor Real y Pontificia de San Francisco Xavier de Chuquisaca (USFX), una institución pública de educación superior en Bolivia ubicada en Sucre, con una historia que data del siglo XVII y enfocada en la formación académica, investigación y extensión comunitaria. El sistema o proceso en cuestión es su aplicación web principal (usfx.bo), que incluye portales para servicios estudiantiles como acceso a bases de datos de estudiantes, programación de cursos, gestión de becas, aulas virtuales y consulta de calificaciones, involucrando procesos automatizados de procesamiento de información sensible como datos personales, académicos y financieros.

¿Qué necesidad existe de hacer este tipo de auditorías?

La necesidad de realizar este tipo de auditorías surge de la exposición creciente a riesgos cibernéticos en instituciones públicas bolivianas, donde las aplicaciones web manejan datos sensibles de miles de usuarios (estudiantes, docentes y administrativos), potencialmente vulnerables a ataques que podrían violar la privacidad, interrumpir operaciones educativas o incumplir regulaciones nacionales

como la Ley de Protección de Datos Personales en Bolivia. Según ISO27005 e ISO31000, estas auditorías son esenciales para identificar riesgos proactivamente, mitigar impactos negativos en la reputación institucional y asegurar la continuidad del negocio educativo en un entorno digital cada vez más hostil, evitando pérdidas financieras o legales derivadas de brechas de seguridad.

Cuál es el alcance de nuestra auditoría, osea a que procesos afecta, unidades organizativas entre otros

El alcance de la auditoría abarca los procesos clave de la aplicación web usfx.bo relacionados con el acceso y manejo de datos, incluyendo autenticación de usuarios, procesamiento de transacciones académicas (como inscripciones y calificaciones), interfaces con bases de datos y aulas virtuales. Afecta unidades organizativas como el Departamento de Tecnologías de la Información (TI), la Administración Académica, el Área de Becas y Financiera, y la Dirección de Seguridad Informática, limitándose a componentes web públicos y no extendiéndose a infraestructura interna como servidores físicos o redes locales, con un enfoque en el período actual de operaciones (2025).

Qué estándares se utilizarán para guiar nuestra auditoría

Los estándares principales son ISO27005 para la gestión de riesgos de seguridad de la información (que guía la identificación de activos, amenazas y vulnerabilidades en contextos de TI) e ISO31000 para la gestión de riesgos organizacionales (que enfatiza el establecimiento de contexto, evaluación y tratamiento de riesgos de manera integrada). Adicionalmente, se incorporan referencias como OWASP Top 10 para amenazas web específicas y el modelo STRIDE para modelado de amenazas, asegurando una auditoría alineada con mejores prácticas globales.

1. Objetivo de la Tarea : Identificar y Determinar qué riesgos son más importantes evaluar en el caso de estudio asignado

El objetivo es identificar al menos 10 riesgos clave basados en amenazas comunes a aplicaciones web educativas, priorizando aquellos con mayor impacto potencial en datos sensibles de estudiantes y operaciones institucionales, para determinar cuáles evaluar en profundidad durante la auditoría, enfocándonos en riesgos que podrían

explotar vulnerabilidades web y comprometer la seguridad según ISO27005 e ISO31000.



2. Identificación de Riesgos:

R1: Broken Access Control. Este riesgo involucra fallos en la aplicación de controles de acceso que permiten a usuarios no autorizados acceder a funciones o datos restringidos, como un estudiante accediendo a calificaciones de otros o modificando registros académicos, lo que podría derivar en violaciones de privacidad y manipulación de información sensible en la app web de USFX, exacerbado por configuraciones predeterminadas débiles o falta de verificación de permisos en endpoints API.

R2: Cryptographic Failures. Se refiere a debilidades en el uso de criptografía, como el empleo de algoritmos obsoletos o almacenamiento inseguro de datos, permitiendo que atacantes descifren información transmitida o almacenada, como credenciales

de usuarios o detalles de becas en el portal de USFX, lo que resulta en exposición de datos personales y potencial robo de identidad si no se implementan protocolos como TLS 1.3 adecuadamente.

R3: Injection. Este riesgo ocurre cuando entradas no confiables se envían a un intérprete como parte de un comando o consulta, como inyecciones SQL en formularios de búsqueda de calificaciones en usfx.bo, permitiendo a atacantes ejecutar código malicioso para extraer o alterar bases de datos de estudiantes, lo que compromete la integridad del sistema si no se usan consultas parametrizadas.

R4: Insecure Design. Implica fallos en el diseño de la aplicación que no incorporan principios de seguridad desde el inicio, como la ausencia de modelado de amenazas en el desarrollo del aula virtual de USFX, llevando a vulnerabilidades inherentes que facilitan ataques como escalamiento de privilegios, lo que afecta la robustez general del sistema contra amenazas emergentes.

R5: Security Misconfiguration. Este riesgo surge de configuraciones predeterminadas insecure, como servidores web expuestos con permisos excesivos o cuentas de administrador por defecto en usfx.bo, permitiendo a atacantes explotar errores para ganar acceso no autorizado a procesos de programación de cursos, resultando en interrupciones operativas si no se aplican hardening regular.

R6: Vulnerable and Outdated Components. Involucra el uso de software o bibliotecas desactualizadas con vulnerabilidades conocidas, como versiones antiguas de CMS o frameworks en la app de USFX, que atacantes pueden explotar mediante exploits públicos para comprometer el sitio, afectando la disponibilidad de servicios como consultas de becas.

R7: Identification and Authentication Failures. Se trata de debilidades en los mecanismos de identificación, como contraseñas débiles o falta de MFA en el login del portal estudiantil de USFX, permitiendo ataques de fuerza bruta o credential stuffing para impersonar usuarios, lo que lleva a accesos no autorizados a datos académicos sensibles.

R8: Software and Data Integrity Failures. Este riesgo ocurre cuando no se verifica la integridad de software o datos, como actualizaciones no firmadas o inyecciones en cadenas de suministro en usfx.bo, permitiendo a atacantes insertar código malicioso que altera calificaciones o procesos de inscripción, comprometiendo la confianza en el sistema.

R9: Security Logging and Monitoring Failures. Implica insuficiente registro y monitoreo de actividades, como la falta de logs detallados en accesos fallidos al aula virtual de USFX, lo que dificulta la detección de brechas en tiempo real y permite que ataques persistan sin ser notados, afectando la respuesta a incidentes.

R10: Server-Side Request Forgery (SSRF). Este riesgo permite a atacantes forzar a la aplicación a realizar solicitudes a recursos internos o externos no intencionados, como en integraciones de API en usfx.bo para bases de datos, potencialmente exponiendo servicios internos o causando denegación de servicio si no se validan entradas de URLs.

3. Evaluación de los Riesgos:

3.1 Perfilamiento de los Riesgos

Se debe Modelar cada amenaza, identificando claramente las vulnerabilidades que aprovecha para que la amenaza se concrete, así como el Agente de Amenaza, y los activos amenazados. Utilice la tabla sobre Modelado de Amenazas.

Id	Riesgo	Amenaza	Descripción	Vulnerabilidades que Aprovecha	Agente de Amenaza	Activos Amenazados
R1	Broken Access Control	Privilege Escalation (escalar privilegios de estudiante a administrador)	Fallos en la aplicación de controles de acceso que permiten accesos no autorizados a funciones o datos.	Falta de verificación de permisos en endpoints, configuraciones predeterminadas débiles.	Hacker externo, usuario malicioso interno (e.g., estudiante)	Bases de datos de calificaciones y registros académicos.
R2	Cryptographic Failures	Credential Theft (robo de contraseñas en texto plano)	Debilidades en criptografía que permiten el descifrado de datos sensibles.	Uso de algoritmos obsoletos, almacenamiento o insecure de claves.	Atacante con herramientas de interceptación (e.g., man-in-the-middle).	Credenciales de usuarios y detalles de becas.
R3	Injection	SQL Injection (lectura o alteración de bases de datos)	Entradas no confiables que permiten la ejecución de código malicioso.	Consultas no parametrizadas, falta de sanitización de inputs.	Hacker externo usando herramientas como SQLMap.	Bases de datos de estudiantes y transacciones académicas.
R4	Insecure Design	Information Disclosure (datos expuestos por mala lógica de interfaz)	Fallos en el diseño que no incorporan seguridad desde el inicio.	Ausencia de modelado de amenazas, falta de principios secure-by-design.	Desarrollador negligente o atacante explotando diseño pobre.	Estructura general del aula virtual y procesos de negocio.
R5	Security Misconfiguration	Cross-Site Scripting (XSS) (por falta de encabezado CSP) • Clickjacking (por falta de X-Frame-Options) • Session Hijacking /	Configuración que exponen el sistema.	Permisos excesivos, cuentas por defecto no cambiadas.	Escáner automático de vulnerabilidades (e.g., script kiddie).	Servidores web e interfaces de programación de cursos.

		CSRF (por cookies sin Secure ni SameSite)				
R6	Vulnerable and Outdated Componentes	Denial of Service (DoS) (aprovechando fallas en bibliotecas)	Uso de componentes desactualizados con vulnerabilidades conocidas.	Bibliotecas no parcheadas, dependencias obsoletas.	Atacante usando exploits públicos (e.g., de CVE database).	Sitio web completo y servicios de consulta de becas.
R7	Identification and Authentication Failures	Session Hijacking (por tokens inseguros)	Debilidades en mecanismos de login y autenticación.	Contraseñas débiles, ausencia de MFA.	Botnets para fuerza bruta o credential stuffing.	Portales de acceso estudiantil y datos personales.
R8	Software and Data Integrity Failures	Tampering de actualizaciones (descargas no firmadas)	Falta de verificación de integridad en software y datos.	Actualizaciones no firmadas, inyecciones en supply chain.	Atacante en la cadena de suministro o insider.	Procesos de inscripción y calificaciones.
R9	Security Logging and Monitoring Failures	Repudiation (usuarios niegan acciones por falta de logs)	Insuficiente registro y monitoreo de actividades.	Logs no detallados, falta de alertas en tiempo real.	Atacante persistente evadiendo detección.	Sistemas de monitoreo y respuesta a incidentes.
R10	Server-Side Request Forgery (SSRF)	Internal Network Scanning (explorar IPs y puertos internos)	Solicitudes forzadas a recursos no intencionados	Validación insuficiente de URLs en inputs.	Hacker externo manipulando APIs.	Recursos internos como bases de datos y servicios conectados.

3.2) Evaluación del Impacto												
Amenaza / vs	Broken Access Control	Cryptographic Failures	Injection	Insecure Design	Security Misconfiguration	Vulnerable and Outdated Componentes	Identification and Authentication Failures	Software and Data Integrity Failures	Security Logging and Monitoring Failures	Server-Side Request Forgery (SSRF)	Puntos (fila)	Ranking
Broken Access Control	-	1/0	1/0	1/0	1/0	0/1	0/1	1/0	1/0	0/1	6	3
Cryptographic Failures	0/1	-	0/1	0/1	1/0	0/1	0/1	0/1	0/1	1/0	2	6
Injection	0/1	1/0	-	1/0	1/0	0/1	0/1	0/1	0/1	1/0	4	5
Insecure Design	0/1	1/0	0/1	-	0/1	0/1	0/1	0/1	0/1	0/1	1	7
Security Misconfiguration	0/1	0/1	0/1	1/0	-	0/1	0/1	0/1	0/1	0/1	1	7
Vulnerable and Outdated Componentes	1/0	1/0	1/0	1/0	1/0	-	1/0	1/0	1/2	1/0	8.5	1
Identification and Authentication Failures	1/0	1/0	1/0	1/0	1/0	0/1	-	0/1	0/1	0/1	5	4
Software and Data Integrity Failures	0/1	1/0	1/0	1/0	1/0	0/1	1/0	-	0/1	1/0	6	3
Security Logging and Monitoring Failures	0/1	1/0	1/0	1/0	1/0	1/2	1/0	1/0	-	1/0	7.5	2
Server-Side Request Forgery (SSRF)	1/0	0/1	0/1	1/0	1/0	0/1	1/0	0/1	0/1	-	4	5

3.3) Evaluación de la Probabilidad o Frecuencia de Ocurrencia												
Amenaza / vs	Broken Access Control	Cryptographic Failures	Injection	Insecure Design	Security Misconfiguration	Vulnerable and Outdated Componentes	Identification and Authentication Failures	Software and Data Integrity Failures	Security Logging and Monitoring Failures	Server-Side Request Forgery (SSRF)	Puntos (fila)	Ranking
Broken Access Control	-	1/0	1/0	1/0	1/0	1/0	1/0	1/0	1/0	1/0	9,0	1
Cryptographic Failures	0/1	-	1/2	1/2	1/2	1/0	1/2	1/0	1/2	1/0	5,5	4
Injection	0/1	1/2	-	1/2	1/2	1/0	1/2	1/0	1/2	1/0	5,5	4
Insecure Design	0/1	1/2	1/2	-	0/1	0/1	0/1	1/0	1/2	0/1	2,5	7
Security Misconfiguration	0/1	1/2	1/2	1/0	-	1/0	1/2	1/0	1/2	1/0	6,0	2
Vulnerable and Outdated Componentes	0/1	0/1	0/1	1/0	0/1	-	0/1	1/0	0/1	1/2	2,5	7
Identification and Authentication Failures	0/1	1/2	1/2	1/0	1/2	1/0	-	1/0	1/2	1/0	6,0	2
Software and Data Integrity Failures	0/1	0/1	0/1	0/1	0/1	0/1	0/1	-	0/1	1/0	1,0	10
Security Logging and Monitoring Failures	0/1	1/2	1/2	1/2	1/2	1/0	1/2	1/0	-	1/2	5,0	6
Server-Side Request Forgery (SSRF)	0/1	0/1	0/1	1/0	0/1	1/2	0/1	0/1	1/2	-	2,0	9

4) Priorizar, de mayor a menor impacto total					
IMPACTO / PROBABILIDAD	DESPRECIABLE (1)	MARGINAL (3)	PROMEDIO (5)	CRÍTICO (7)	CATASTRÓFICO (10)
CASI SIEMPRE (10)	—	—	Privilege Escalation (escalar privilegios de estudiante a administrador)	—	—
MUY FRECUENTE (7)	Clickjacking (por falta de X-Frame-Options)	Session Hijacking (por tokens inseguros)	—	—	Denial of Service (DoS) (aprovechando fallas en bibliotecas)
MEDIANAMENTE (5)	Information Disclosure (datos expuestos por mala lógica de interfaz)	—	—	Repudiation (usuarios niegan acciones por falta de logs)	—
POCO FRECUENTE (3)	SQL Injection (lectura o alteración de bases de datos)//Credential Theft (robo de contraseñas en texto plano)	—	Tampering de actualizaciones (descargas no firmadas)	—	—
CASI NUNCA (1)	Internal Network Scanning (explorar IPs y puertos internos)	—	—	—	—